

ANÁLISIS DE BRECHAS VS. MEJORES PRÁCTICAS

Seguridad preventiva y de respuesta en redes de datos

► **Areli Alejandra Guevara Badillo**

► *Miércoles, 26 de octubre de 2025*

1. Introducción y Objetivo

Este documento representa la fase analítica y más crítica del proyecto de seguridad. Mientras que las memorias técnicas anteriores se centraron en el "qué", este informe se enfoca en el "y qué". Su objetivo principal es realizar un análisis comparativo exhaustivo entre el estado actual de las configuraciones y las mejores prácticas recomendadas por la industria, utilizando el marco de trabajo **CIS Controls v8** como vara de medir para identificar, explicar y contextualizar cada brecha de seguridad.

A diferencia de los documentos descriptivos que lo preceden, este informe es evaluativo. Se busca transformar los datos brutos de la auditoría en inteligencia accionable, explicando el "porqué" detrás de cada recomendación y el impacto potencial de no abordar las vulnerabilidades encontradas. Este análisis no solo enumera las fallas, sino que también establece el nivel de riesgo que representan para la integridad de la red y la confidencialidad de los datos. Esta evaluación es el pilar fundamental sobre el cual se construirá el plan de acción y remediación en la memoria técnica final.

2. Análisis Comparativo de la Infraestructura de Red

La infraestructura de red, centrada en el router **Huawei HG8145V5**, es la primera línea de defensa. A continuación, se desglosan las brechas de seguridad encontradas en su configuración.

Control	Estado Actual	Mejor Práctica	Análisis de la Brecha	Impacto Potencial
Contraseña Wi-Fi	La contraseña de la red Wi-Fi consta de 10 caracteres y no utiliza mayúsculas ni símbolos.	Las redes Wi-Fi con una contraseña robusta, idealmente una contraseña de 15 a 20 caracteres como mínimo, que combine mayúsculas, minúsculas, números y símbolos. El objetivo es maximizar la entropía para hacer inviables los ataques de fuerza bruta.	Una contraseña de 10 caracteres compuesta solo por minúsculas y números es computacionalmente trivial de descifrar con hardware moderno. Una vez obtenida, el atacante tiene acceso total a la red interna.	Acceso no autorizado a la red, interceptación de tráfico (ataques Man-in-the-Middle), uso del ancho de banda, y punto de partida para atacar a otros dispositivos dentro de la red.
Wi-Fi Protected Setup (WPS)	El servicio WPS está habilitado.	WPS debe estar permanentemente deshabilitado en la configuración del router. No ofrece un beneficio de usabilidad que compense su enorme riesgo de seguridad.	WPS es un protocolo fundamentalmente roto con vulnerabilidades de diseño conocidas que no pueden ser corregidas. La vulnerabilidad más crítica reside en su método de autenticación por PIN. Un atacante puede lanzar un ataque de fuerza bruta contra el PIN de 8 dígitos de forma mucho más eficiente de lo que parece, ya que el PIN se valida en dos mitades.	Un atacante puede obtener la contraseña de la red, sin importar su longitud o complejidad, eludiendo así la principal barrera de protección de la red inalámbrica.
Universal Plug and Play (UPnP)	El servicio UPnP está habilitado.	UPnP debe estar permanentemente deshabilitado. La gestión de puertos debe realizarse de forma manual solo cuando sea estrictamente necesario y para dispositivos específicos.	UPnP opera bajo un modelo de "confianza implícita", permitiendo que cualquier dispositivo o aplicación en la red local solicite al router que abra puertos hacia Internet sin ninguna autenticación o autorización del usuario.	Exposición de servicios internos a ataques externos, persistencia de malware en la red, facilitación de la exfiltración de datos y conversión de la red en parte de una botnet.

Red de Invitados	La funcionalidad de red de invitados está deshabilitada.	Se debe habilitar una red de invitados con una contraseña fuerte e independiente. Crucialmente, la opción de "aislamiento de cliente" (Client Isolation) debe estar activada para impedir que los dispositivos conectados a esta red se comuniquen entre sí o con la red principal.	Al no tener una red segmentada, todos los dispositivos coexisten en el mismo dominio de difusión. Esto significa que un dispositivo tiene visibilidad y acceso de red a los equipos más importantes, como computadoras personales con datos sensibles.	Un dispositivo comprometido de bajo valor puede ser utilizado como un "pivote" para lanzar ataques de movimiento lateral contra activos de alto valor dentro de la misma red. Aumenta drásticamente la superficie de ataque interna.
-------------------------	--	--	--	--

El análisis de la infraestructura de red demuestra que la principal línea de defensa tiene debilidades significativas e ignora principios de seguridad fundamentales, como los establecidos por el marco de trabajo CIS Controls. Aunque se cuenta con un firewall, su protección se ve comprometida por funciones de conveniencia, como WPS y UPnP, que en la práctica crean entradas ocultas para posibles atacantes. A esto se suma una contraseña de Wi-Fi débil que facilita el acceso no autorizado.

La falta de una red separada para invitados agrava el problema, ya que obliga a que todos los dispositivos, desde computadoras importantes hasta televisores inteligentes o teléfonos de visitantes, compartan el mismo espacio. Esto es riesgoso porque si un dispositivo menos seguro es comprometido, puede atacar fácilmente a los equipos más críticos de la red.

La configuración actual prioriza la facilidad de uso por encima de una seguridad sólida. Esto crea un entorno donde las defensas principales pueden ser superadas con relativa facilidad, dejando la información y los dispositivos importantes expuestos a amenazas considerables.

3. Análisis Comparativo de los Dispositivos Finales

ID	Nombre	Tipo	Brecha de Seguridad Específica y Riesgo Asociado
003	DesktopGUEBA	Computadora	Cifrado de disco no habilitado. Riesgo: → En caso de robo físico, toda la información del disco es accesible, resultando en una fuga total de datos.
004, 008	LaptopVenuz	Computadora	Cifrado de disco no habilitado. Bloqueo automático deshabilitado. Riesgo: → Fuga total de datos en caso de robo. → El equipo permanece desbloqueado si se deja desatendido, permitiendo acceso no autorizado.
005	Roku Guebadillo	IoT	Conectado a la red principal. Riesgo: → Los dispositivos IoT son objetivos frecuentes de ataque. → Puede ser usado como un punto de pivote para atacar otros dispositivos críticos en la red.
006	Redmi-Note-11	Smartphone	Capacidad de borrado remoto no configurado. Riesgo: → En caso de robo o pérdida, no hay forma de proteger los datos almacenados.
007	Redmi-Note-11	Smartphone	Capacidad de borrado remoto no configurado. Riesgo: → En caso de robo o pérdida, no hay forma de proteger los datos almacenados.
009, 016	DBR-W09	Computadora	Dispositivo no gestionado ("Sin acceso"). Riesgo: → Su estado de seguridad es desconocido, representando un punto ciego y un riesgo activo la red.
010	(Sin Nombre)	Desconocido	Dispositivo no identificado y no gestionado.

			Riesgo: → No se conoce su propósito ni su propietario. Podría ser un dispositivo malicioso conectado a la red.
011	dg60774	Computadora	Cifrado de disco no habilitado. Copias de seguridad deshabilitadas. Riesgo: → Fuga de datos en caso de robo y pérdida permanente de información ante un fallo.
012	(Sin Nombre)	Desconocido	Dispositivo no identificado y no gestionado. Riesgo: → El riesgo más alto. Su presencia es una brecha crítica de seguridad que requiere acción inmediata.
013	POCO-M5s	Smartphone	Permite instalar apps de fuentes no oficiales. Borrado remoto no configurado. Riesgo: → Alto riesgo de infección por malware. → En caso de pérdida, los datos quedan expuestos.
014, 015	Xiaomi-12-Pro	Smartphone	Dispositivo no gestionado ("Sin acceso"). Riesgo: → Actúa como una "caja negra" en la red. Su estado de seguridad es desconocido.
017	HUAWEI_nova_3-a8	Smartphone	Dispositivo no gestionado ("Inactivo"). Riesgo: → Aunque inactivo en el momento de la auditoría, si se conecta, representa un activo no gestionado.
018	Xiaomi-12-Pro	Smartphone	Permite instalar apps de fuentes no oficiales. Borrado remoto no configurado. Riesgo: → Alto riesgo de infección por malware. En caso de pérdida, los datos quedan expuestos.
019	Redmi-Note-11	Smartphone	Dispositivo no gestionado ("Inactivo"). Riesgo: → Si se conecta, representa un activo no gestionado.

Los dispositivos finales son, a menudo, el eslabón más débil de la cadena de seguridad. El análisis de su estado actual revela brechas críticas.

Brecha 1: Falta de Cifrado de Datos en Reposo

- **Observación:**
En todas las computadoras gestionadas (IDs 003, 004, 008, 011), el cifrado de disco completo (BitLocker) no está habilitado.
- **Análisis de la Brecha:**
El cifrado de disco protege los datos cuando el dispositivo está apagado. Sin él, la protección de la contraseña de inicio de sesión de Windows es una barrera trivial. Un atacante con acceso físico al equipo puede simplemente extraer el disco duro, conectarlo a otra máquina y leer todo su contenido como si fuera una unidad USB.
- **Impacto Potencial:**
Fuga total de la información almacenada en los discos duros. Esto incluye documentos personales y profesionales, fotos, datos de navegación, contraseñas guardadas en navegadores, claves de acceso a software y cualquier otro dato sensible. Conduce directamente al robo de identidad, pérdida financiera y compromiso de otras cuentas en línea.

Brecha 2: Gestión de Seguridad Inconsistente en Dispositivos Móviles

- **Observación:**
En los smartphones a los que se tuvo acceso, la capacidad de borrado remoto no está configurada. Además, en algunos dispositivos se permite la instalación de aplicaciones desde tiendas no oficiales, mientras que en otros no.
- **Análisis de la Brecha:**
 1. **Sin Borrado Remoto:** Los smartphones son los dispositivos con mayor probabilidad de pérdida o robo. La capacidad de borrado remoto es la última línea de defensa, permitiendo al propietario destruir todos los datos del dispositivo a distancia para evitar que caigan en manos equivocadas.
 2. **Instalación de Apps no Oficiales:** Las tiendas oficiales como Google Play Store tienen mecanismos (aunque no infalibles) para detectar y eliminar aplicaciones maliciosas. Las fuentes no oficiales no tienen estos filtros, convirtiéndose en un canal de distribución principal para spyware, ransomware, troyanos bancarios y otro malware.
- **Impacto Potencial:**
Pérdida permanente de datos sensibles en caso de robo. Infección de la red interna con malware avanzado que puede robar credenciales bancarias, espiar comunicaciones o secuestrar archivos.

Brecha 3: El Punto Ciego de los Activos no Gestionados

- **Observación:**
La mayoría de los dispositivos en la red son de terceros o desconocidos (IDs 009, 010, 012, 014, 015, 016, 017, 019), y no se tiene ningún acceso a su configuración.
- **Análisis de la Brecha:**
Esta es, posiblemente, la brecha de seguridad más crítica de la red. Estos dispositivos representan una superficie de ataque completamente desconocida y no gestionada. Operan bajo un modelo de "confianza implícita" una vez que se conectan a la red Wi-Fi.

- **Impacto Potencial:**

Compromiso total de la red desde adentro hacia afuera. Un atacante podría interceptar todo el tráfico, plantar ransomware en las computadoras, acceder a archivos compartidos y utilizar la red como base para lanzar ataques contra otros objetivos en Internet.

4. Conclusión General del Análisis de Brechas

El análisis comparativo ha revelado que la postura de seguridad actual de la red es deficiente y no cumple con los estándares básicos de protección recomendados. Las brechas identificadas no son incidentes aislados, sino que forman un patrón de riesgo interconectado que abarca tanto la infraestructura de red como los dispositivos finales.

Por un lado, la infraestructura perimetral, que debería ser la primera línea de defensa, está debilitada por configuraciones permisivas que priorizan la conveniencia sobre la seguridad.

Por otro lado, el análisis de los endpoints ha sacado a la luz la vulnerabilidad más crítica: una falta fundamental de control y visibilidad sobre la mayoría de los activos conectados. La presencia de dispositivos desconocidos y no gestionados viola los principios más elementales de la ciberseguridad, como los establecidos en los **CIS Controls 1 y 2**, creando un entorno de "confianza implícita" donde las amenazas internas pueden prosperar sin ser detectadas.

Concluimos entonces que la red opera con un falso sentido de seguridad. Las defensas externas son eludibles y el entorno interno presenta múltiples puntos ciegos que representan un riesgo inaceptable. Este informe ha cumplido su objetivo de identificar y contextualizar estas brechas.

El siguiente y último paso será utilizar esta inteligencia para construir una **Memoria Técnica 4**, que definirá un estado deseado de seguridad y presentará un plan de trabajo para remediar estas vulnerabilidades.